ISO27001 Risk Register	Organization: Stratford Pay Solutions LTD (simulated organization)	Prepared by: Tibor Marton	Date: March 2026

Company Overview: Stratford Pay Solutions Ltd is a UK-based fintech company providing digital payment processing services to small and medium-sized businesses. The company processes financial transactions and stores limited customer information within its systems.

ID	Risk Description	Asset	Threat	Vulnerability	Likelihood	Impact	Risk Score	Risk Level	Existing Controls	Recommended Controls	Risk Owner	ISO Control Reference
R1	Phishing attack compromises employee accounts	Email system	Phishing	Low security awareness	3	3	9	High	Email spam filtering	Security awareness training and phishing simulations	IT Security Manager	A.7 Security Awareness
R2	Unpatched laptops exploited by malware	Employee laptops	Malware	Delayed patching	3	2	6	Medium	Antivirus installed	Automated patch management	IT Operations Manager	A.12 Operations Security
R3	Weak passwords allow unauthorised access	Corporate systems	Credential attack	Weak password policy	2	3	6	Medium	Basic password requirements	Enforce multi-factor authentication (MFA)	IT Security Manager	A.9 Access Control
R4	Customer database exposed due to misconfigured cloud storage	Customer database	External attacker	Cloud misconfiguration	2	3	6	Medium	Limited access permissions	Cloud configuration review and monitoring	Cloud Administrator	A.12 Operations Security
R5	Ransomware encrypts company data	File storage	Ransomware	Lack of offline backups	2	3	6	Medium	Endpoint antivirus	Implement offline and tested backups	IT Operations Manager	A.12 Operations Security
R6	Former employee retains access to company systems	Identity system	Insider threat	Poor access revocation	2	2	4	Medium	Manual offboarding process	Automated access removal during offboarding	HR / IT Manager	A.9 Access Control
R7	Sensitive data shared externally by mistake	Email / file sharing	Human error	Lack of data classification	2	2	4	Medium	Email access controls	Implement data classification policy and training	Compliance Manager	A.8 Asset Management
R8	Third-party SaaS provider suffers data breach	CRM system	Supply chain compromise	Vendor security unknown	2	3	6	Medium	Vendor contracts	Third-party risk assessments and security reviews	Compliance Manager	A.15 Supplier Relationships
R9	Lost or stolen laptop exposes company data	Employee laptop	Physical theft	No disk encryption	2	2	4	Medium	Device login passwords	Enable full disk encryption	IT Operations Manager	A.11 Physical Security
R10	Distributed denial-of-service attack disrupts company website	Website	DDoS attack	Lack of protection services	1	2	2	Low	Basic firewall	Implement DDoS protection service	IT Infrastructure Manager	A.13 Network Security